Handoff 17: Anonymous feedback storage and limits (FB-02)

Date: 2026-10-27 (America/Toronto)
Written by: Claude Code (implementer)
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#24), backend only, not merged, not deployed. **Database migration 0008** (adds one table).

> **How to use this file:** upload it with `build.md`, `docs/plan/feedback-security.md` (the source of truth) and `docs/plan/backlog.md` (FB-01 to FB-07). The pull request diff is the source of truth for the code (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing Python Academy stage 17 (FB-02): the server side of
anonymous tester feedback. Testers (students the admin has marked) and the
admin can send a short message, a category, an optional audience and,
only if they opt in, their code. Nothing stored identifies the sender.
There are rate limits, length limits, deletion after 50 days and a
90-item cap. I'm attaching build.md, docs/plan/feedback-security.md and
this handoff. Check that nothing stored, returned or logged can identify
a tester, that only testers and the admin can send, that the cap never
silently drops unresolved feedback, and question the choice of in-memory
rate limits. Explain at a first-year computer engineering level.
```

1. Step 0 (checks before building)

Check	Result
`git fetch --all`, `gh pr list --state all`	Done
Admin PR (FB-01, `feat/admin-role`) merged?	**Yes**: PR #21, merged 2026-10-27
`main`'s migration head	**0007** (`0007_admin_and_testers.py`, `down_revision = '0006'`)
Earlier FB-02 work on any branch, commit, stash or PR	**None**

Check	Result
Branch	`feat/feedback-storage` from `origin/main` at `4f58d96` (after PR #23). Not stacked on anything

(An earlier request for this task on 2026-10-27 stopped at step 0, because PR #21 was not merged yet.)

2. Handoff record (build.md template)

Field	Value
Task	FB-02: an anonymous `feedback` table (migration 0008); a submit route for testers and the admin only, with length limits, fixed categories, an optional audience and opt-in code; rate limits whose counters hold no text; 50-day retention and a 90-item cap
Human goal	Testers can report problems without being identifiable, and the inbox cannot be flooded or keep data too long
Relevant sections	`build.md` sections 11 and 12; `feedback-security.md` sections 2 to 8; backlog decisions 12, 17 and 18
Repository and branch	`torontojohn/python-academy`, branch `feat/feedback-storage`
Base commit / head	Base `4f58d96`. Code and tests in `5b65634`; documents in the commits after it
Implementer / reviewer	Claude Code / the owner and a chat assistant
Non-goals	The feedback button and form (FB-05), the admin inbox and any way to read items (FB-06), the digest (FB-07), any frontend change, the page context fields (section 9)
Data migration	**0008**: creates `feedback`. Additive, so the previous app version keeps working during the deploy. **Downgrading deletes every feedback item**
Deployment status	Not requested

Files changed

File	Why
`backend/app/feedback.py` (new)	The guard, the request schema, text cleaning, the cap and retention, the route, and the hourly retention check
`backend/app/db.py`	The `Feedback` model
`backend/migrations/versions/0008_feedback.py` (new)	Creates the table; the downgrade drops it

File	Why
`backend/app/limits.py`	A `feedback` rule, and an optional shared counter for everyone together (`everyone`)
`backend/app/main.py`	Registers the feedback route (imported as `tester_feedback`, because `main.py` already uses `feedback` as a variable name)
`backend/tests/test_feedback.py` (new)	33 tests
`backend/tests/test_migrations.py`	Migration head is now 0008; a 0008 up-and-down test
`backend/tests/test_sessions.py`	The route-listing safety test knows the new tester-only route
`docs/plan/feedback-security.md`	Status line, including the rate-limit difference
`docs/plan/decision-log.md`	Chapter 15
`docs/handoffs/2026-10-27-17-feedback-storage.md` and `.pdf`	This handoff

`docs/plan/backlog.md` is **not** edited (section 10 lists the rows to change).

3. How it works

`POST /api/feedback`, registered on the app itself (not an included router), with two guards in this order:

1. `require_tester`**:** 401 when signed out. 403 unless the account is a student with the tester flag, or an admin. Admin means an admin session, as in FB-01.
2. `limit('feedback')`**:** at most 5 an hour and 20 a day per tester, and 60 a day for all testers together.

The body (JSON; unknown fields are refused):

Field	Rule
`category`	One of `confusing`, `bug`, `wrong_grading`, `idea`, `other` (the five types in the spec)
`message`	1 to 2,000 characters, and not only spaces
`audience`	Optional: `high_school`, `university` or `other`
`include_code`	`true` only if the sender ticked "Include my code"; default `false`
`code`	Up to 20,000 characters. **Stored only when** `include_code` **is true**; otherwise thrown away

Before storing: - Control characters (except new lines and tabs) and the Unicode direction overrides are removed. - Email addresses and phone numbers in the message become `[email removed]` and `[number`

`removed]`. This is best effort; names cannot be detected. - HTML is stored as plain text. The inbox (FB-06) must show it as text.

The stored row: - `id`, `created_on` (the **date** only), `category`, `audience`, `message`, `code`, `status` (`new` at first). - No user ID, name, email, IP address or session ID, and no foreign key to any other table. - The response is only `{"saved": true}`. - Sending feedback adds **no** account-history event. - The log line says only `Feedback accepted` or `Feedback rejected: inbox full`.

Retention and cap: - **50 days:** an item sent on day D is deleted on day D + 50. This is checked: - every time feedback is sent - at most once an hour on any request, so items go on time even when nobody sends feedback - **90 items:** when the inbox is full, the oldest **resolved** item (`fixed` or `wont_fix`; oldest date first, then lowest ID) is deleted to make room. If nothing is resolved, the new item is refused with **409**: "The feedback inbox is full right now, so this was not saved. Please try again in a few days." Unresolved items are never deleted to make room. - Submissions are handled one at a time, so two at once cannot both take the last place. This holds for one API instance, which is what runs today.

Statuses (`new`, `triaged`, `in_progress`, `fixed`, `wont_fix`) exist as values only. Nothing can change them until the inbox (FB-06).

4. Decisions and why

Decision	Options considered	Reason	Who decided
Rate limits in the existing in-memory counters (`limits.py`)	A database counter table with an HMAC of the user ID, hourly windows and 24-hour deletion (`feedback-security.md` section 7)	The task says to use the existing `limits.py` approach. Those counters already hold only a keyed hash, a window start and a count, never text, and are never stored next to a message. **Trade-off:** they reset when the API redeploys, so a tester could send another 5 right after a deploy. The 90-item cap still bounds the damage	Owner (task), recorded here; question 1
Limits: 5 an hour and 20 a day per tester; 60 a day for everyone	Other numbers	The examples in `feedback-security.md` section 3	Spec
The "everyone" counter only counts requests that passed the sender's own limit	Count every request	Otherwise one blocked tester could use up everyone's allowance	Implementer
A refused request still counts towards the limits	Count only accepted ones	That is how every existing limit works; changing it for one rule would be surprising	Existing behaviour

Decision	Options considered	Reason	Who decided
Store the **date**, in UTC, not the time	A timestamp	`feedback-security.md` section 7: a time could be matched to sign-ins or request logs	Spec
Full inbox with nothing resolved: **409** with a clear message	503, 507, or deleting an unresolved item	Nothing is wrong with the server, and decision 18 says never to drop unresolved items	Implementer (status code) / owner (rule)
Retention checked when feedback is sent and at most hourly on any request	A cron job or worker	No new service or cost. If retention fails, the app keeps working and logs only the error type	Implementer
Remove control and direction characters; replace emails and phone numbers	Store exactly what was typed	`feedback-security.md` sections 2 and 5 put these on the server, before storing	Spec (**assumption 1**: in scope for FB-02)
Code sent without `include_code` is **dropped silently**, not refused	Answer 422	The spec: "without the box ticked, no code is stored even if the request includes some"	Spec
The response does not include the item's ID	Return the ID	The sender has no use for it until there is a status view, which anonymity rules out (FB-08 dropped)	Implementer
No route to read items	A minimal admin read route	The task: reading is FB-06. The tests read the database directly	Owner (task)
The page context (page, lesson, task, content version, browser) is **not** stored yet	Add the columns now	The task listed the fields to build; the form that sends context is FB-05. Adding them later needs migration 0009	Implementer (**question 2**)

5. Bugs found and how they were fixed

Bug or near-miss	How it was found	Fix
A test helper named `tester()` was run by pytest as a test, because its name starts with "test"	pytest's "returned a value" warning	Renamed `as_tester()`; the warnings are back to the usual two
Near-miss: my first daily-limit test assumed refused requests do not count	The test failed	The test now states the rule (section 4)

Bug or near-miss	How it was found	Fix
Near-miss: two tests sent more than 5 items within an hour and hit the limit they were not testing	The tests failed	They reset the counters between sends; the limits have their own tests
Near-miss in the local check: a curl helper sent two `Origin` headers, so the "other website" request was not tested there	Reading the result (429 instead of 403)	Not a code problem: the pytest test sends one header and gets 403

No bugs were found in the existing code.

6. How it was tested

Commands and results (on `5b65634`, macOS, Python 3.12.14, Node 24)

Command	Result
`cd backend && DATABASE_URL=sqlite:///<temp>.db .venv/bin/python -m pytest -q`	**316 passed, 11 skipped**
Same with `TEST_POSTGRES_URL=<local PostgreSQL 16 from pgserver>`	**327 passed** (the migration tests also run on PostgreSQL)
`cd backend && … pytest -q tests/test_feedback.py`	**33 passed**
`cd frontend && npx tsc --noEmit && npm run build && CI=1 npx playwright test`	Types and build OK; **83 passed** (no frontend change)

`DATABASE_URL` points at a throwaway file because a local, git-ignored `academy.db` can be at a different migration than the branch. CI has no such file.

What the tests cover

Required test	Where
401 and 403 for each role (signed out, pending, parent, student, tester, admin)	`test_only_testers_and_the_admin_can_send`: 401; 403 ×4, including a parent with the tester flag; 200 ×2. Also the admin's email with an ordinary session gets 403, and a student gets 403 once the flag is cleared
Anonymity: the stored row and every response hold no user ID, email, IP or session ID	`test_nothing_stored_or_returned_identifies_the_sender`. It sends with made-up `cf-connecting-ip` and `X-Forwarded-For` headers, checks the exact columns, the date-only type, and that neither email, IP, session ID nor user ID appears. Also `test_sending_feedback_adds_nothing_to_the_account_history`

Required test	Where
A student who is not a tester cannot send	The role test, and the flag-cleared test
Length limits and category validation	2,000 accepted and 2,001 refused; empty and only spaces refused; code at 20,000 accepted and 20,001 refused; wrong category, wrong case, unknown audience, and extra fields such as `user_id` or `email` refused
Code saved only when opted in	Six combinations; only `include_code: true` with real code is stored
Rate limits	5 an hour with `Retry-After`; 20 a day; 60 a day across 13 testers; the counters hold only 32-character hashes, a start and a count, with no message, code, email or `u:<id>`
Retention at exactly 50 days, fake clock	Kept on day 49, gone on day 50; also runs when feedback is sent
The 90-item cap and which items go first	The oldest `fixed`, then the next `fixed` (same day, lower ID), then `wont_fix`. Older unresolved items are untouched
Rejected when full of unresolved items	409 with the exact message; nothing deleted; "rejected" logged
No message text in any log line	One test runs accepted, too long, rate-limited, inbox full, the admin, and retention, then checks the logs for the message, code, email addresses and user ID
Migration 0008 up and down	SQLite always and PostgreSQL in CI: exact columns, a `Date` column, no foreign keys, default status `new`; the downgrade removes the table and keeps accounts and sessions; upgrading again reaches 0008. The existing "migrations match the models" test also covers the table
Other	Writes from another website, or with no `Origin`, get 403; a retention failure never takes the app down

Deliberate-break controls (each undone; the file matched the saved copy byte for byte afterwards)

What I broke	Tests that failed
1. Record the sender in the account history (an event with their user ID)	1: `test_sending_feedback_adds_nothing_to_the_account_history`
1b. Store the sender's email in the feedback row	2: `test_nothing_stored_or_returned_identifies_the_sender`, `test_every_category_and_audience_is_accepted`

What I broke	Tests that failed
2. Remove the tester check (any signed-in account may send)	6: the role test for pending, parent, student and a parent with the flag; admin email with an ordinary session; flag cleared
3. A full inbox deletes the oldest item of any status	3: oldest resolved first; full of unresolved; the log test (no "rejected" line)
4. Retention one day late	2: exactly 50 days; retention when sending
5. Store code without opting in	1: `test_code_is_saved_only_when_the_sender_opts_in`
6. Log the message text	1: `test_no_message_code_email_or_user_id_in_any_log_line`

The real API, no mocks (local)

A fresh SQLite database, `uvicorn app.main:app`, real session cookies, and curl: - The log shows `Database schema is at migration 0008`. - Signed out gave **401**; a parent **403**; a non-tester student **403**; a tester **200**, four more times **200**, then **429**. - The table held the two columns of text and the opted-in code, with no account fields. There were no account-history events. - The log had five `Feedback accepted` lines and two `Rate limited: rule=feedback scope=user` lines. It contained no message, code or email.

Mocks: the pytest tests replace only Google's answer (for the admin sign-in) and the clock. The database, sessions and routes are real.

7. Known limitations

- **Rate limits reset on redeploy** (section 4). If the API ever runs on more than one instance, the limits and the one-at-a-time rule apply per instance.
- **Removing emails and phone numbers is best effort.** It does not catch names, addresses, or numbers written in words.
- **No way to read, resolve or delete items yet** (FB-06), so the cap can only fill up. Once 90 unresolved items exist, new feedback is refused until the inbox ships.
- **Anonymity has limits** (`feedback-security.md` section 8). Render's request logs record the IP address and time of each request. With very few testers, items are easy to attribute.
- **No page context is stored yet** (question 2).
- **Downgrading 0008 deletes all feedback.**

8. Open PRs and conflicts

None open besides this one; it is based on `main` after PR #23.

9. Live checks for you after merging

Merging redeploys the API. Nothing new is needed in Render; there are no new settings.

- [ ] **Migration 0008.** Render → python-academy-api → Logs shows `Database schema is at migration 0008`.
- [ ] **Signed out gets 401.** In a terminal:

```
sh curl -s -o /dev/null -w "%{http_code}\n" -X POST https://python-academy-dji8.onrender.com/api/feedback -H 'Origin: https://python-academy-dji8.onrender.com' -H 'Content-Type: application/json' -d '{"category":"bug","message":"live check"}'
```

It prints `401`. (`403` would mean the `Origin` is not the app's address in `DEPLOYMENT.md`.) - [ ] **A non-tester student gets 403.** Signed in to the app as a student who is not a tester, in DevTools → Console:

```
js (await fetch('/api/feedback', {method: 'POST', headers: {'Content-Type': 'application/json'}, body: JSON.stringify({category: 'bug', message: 'live check'})})).status
```

It returns `403`. - [ ] **A tester gets in.** Set a student as tester (handoff 12 section 9), sign in as them, and run the same line. It returns `200`. - [ ] **The limit.** Run it five more times as the tester. The sixth in the hour returns `429`. - [ ] **Nothing identifies the tester.** Render → the database → **Connect** → the PSQL command, then:

```
sql \d feedback SELECT id, created_on, category, audience, status, code IS NOT NULL AS has_code FROM feedback;
```

The table has no user, email, IP or session column, and `created_on` is a date with no time. - [ ] **Logs hold no text.** Search the API logs for `live check`: nothing. You see `Feedback accepted` lines only. - [ ] **Clean up (optional):** `DELETE FROM feedback;` in the same PSQL session removes the test items.

10. Backlog rows to change (not edited, as asked)

ID	Change
FB-02	proposed → in_review (#24, handoff 17). Note: rate limits are in memory, not a database table (decision in section 4)
OPS-04	Note: feedback retention (50 days, 90 items) is built in FB-02; goals and placement data still to be decided
FB-05	Note: the form must send `include_code` only when the box is ticked. Page context needs migration 0009, if wanted (question 2)
FB-06	Note: needs status changes and deletion, or the 90-item cap will block new feedback once full
Stage table	Add "17. FB-02 | Anonymous feedback storage and limits | in_review (#24, handoff 17)"

11. Questions for the owner

1. **Rate limits in memory** reset on redeploy. Is that acceptable for now, or do you want the database counter table from `feedback-security.md` section 7, as a small follow-up with migration 0009?
2. **Page context:** should feedback store the page, lesson, task, content version and browser type, as the spec's form describes? If yes, add the columns now (in this PR) or with FB-05?
3. **Removing emails and phone numbers** (assumption 1): keep it in FB-02?
4. **Audience values:** are `high_school`, `university` and `other` the right three?

12. Next concrete action

Review and merge, then run the live checks in section 9. FB-03 is mostly done (stage 12), so FB-04 (the tester page) and FB-05 (the button and form) are next. FB-06 (the inbox) waits for SEC-09 enforcement.